

Contents

Executive Summary	2
Compromised Data	3
Incident Overview	4
Initial Entry Point:	4
Intrusion Timeline:	4
Detection:	4
Scope of the Breach	5
Compromised Data.....	5
Systems Affected:	5
Indicators of Compromise (IOCs):.....	5
Vulnerabilities Exploited	5
Business Impact Analysis	6
Operational Impact.....	6
Financial Impact	6
Legal and Compliance Impact.....	6
Reputational Impact.....	6
Recommendations	6
Immediate Actions	6
Long-Term Strategic Improvements	6
Lessons Learned	7
Conclusion.....	7

The Task

Orion Health Services is a mid-sized healthcare technology provider with 250 employees. They manage sensitive patient data and provide cloud-based software to clinics across Australia and New Zealand.

On Monday morning, the IT team noticed unusual outbound traffic from one of their internal servers. By midday, several employees reported being locked out of systems, and a ransom note appeared on the shared drive.

You are a **Cybersecurity Analyst Graduate** on the internal security team. You've been asked to assist in investigating the incident and preparing a report for the executive team.

Incident Type: Ransomware attack

Initial Entry Point: A phishing email sent to a finance team member, containing a malicious Excel attachment

Compromised Data:

- Employee payroll records
- Patient appointment schedules
- Internal system credentials

Systems Affected:

- File server
- HR and finance systems
- Backup server (partially encrypted)

Indicators of Compromise (IOCs):

- Suspicious login from an overseas IP
- Use of Mimikatz for credential harvesting
- files with .orionlock extension

Executive Summary

On Monday morning, Orion Health Services noticed unusual outbound traffic from an internal server, then followed by widespread system access issues and a ransom note appearing on the shared drive. The incident was confirmed as a ransomware attack originating from a phishing email sent to a finance team member containing a malicious Excel attachment.

Compromised Data

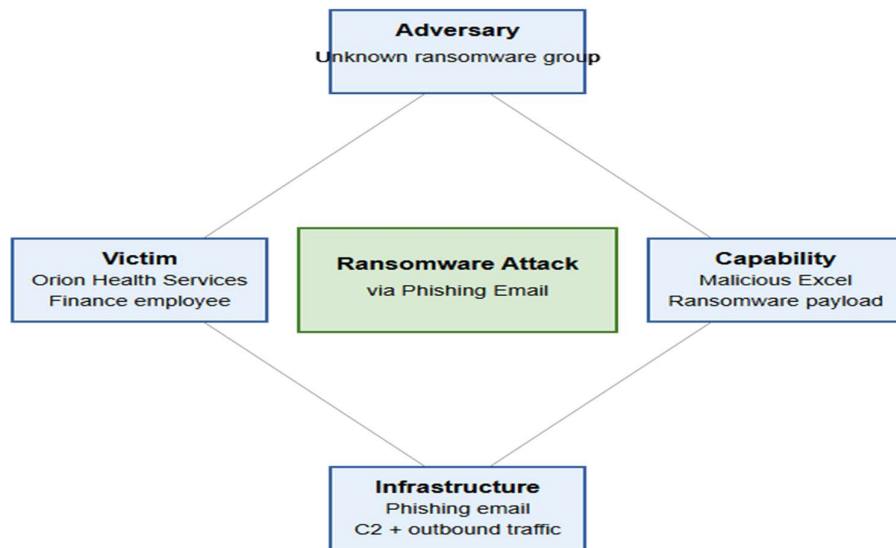
The attack has compromised sensitive data (employee payroll records, patient appointment schedules, and internal system credentials). Multiple critical systems were affected, including the file server, HR and finance systems, and portions of the backup infrastructure.

This incident causes significant operational, financial, legal, as well as reputational risks to the organisation.

Incident Overview

Initial Entry Point:

- Phishing email sent to finance employee
- Malicious Excel attachment executed (likely containing malware)



Appendix A: Application of the Diamond Model of Intrusion Analysis to the Orion Health Services incident, showing how a phishing email (infrastructure) enabled delivery of a malicious Excel attachment (capability) to a finance employee (victim), linked to an unknown ransomware adversary.

Intrusion Timeline:

- Malware executed and established an entry point.
- Credentials harvested using tools such as Mimikatz.
- Suspicious login detected from overseas IP (indicating likely lateral movement or remote access).
- Privilege escalation enabled wider system access.
- Ransomware deployed across the network.

Detection:

- Unusual outbound traffic detected (possible data exfiltration).
- Employees locked out of systems.
- Ransom note discovered on shared drive.

Scope of the Breach

Compromised Data

- Employee payroll records (sensitive financial information).
- Patient appointment schedules (health related (PII) personal identifiable information).
- Internal system credentials (high risk for further exploitation).

Systems Affected:

- File server (encrypted)
- HR and finance systems (compromised)
- Backup server (partially encrypted and reduces recovery from back up).

Indicators of Compromise (IOCs):

- Unusual login activity from overseas IP address.
- Execution of credential dumping tools
- Files encrypted with *.orionlock* extension

Vulnerabilities Exploited

The attackers leveraged multiple weaknesses:

- Lack of users' security awareness or insufficient email filtering allowed a malicious attachment to be opened.
- lack of least privilege Over-privileged accounts or allowed lateral movement.
- Lack of multi-factor authentication allowed attackers to use stolen credentials without additional verification.
- Insufficient endpoint detection delayed detection of credential harvesting and suspicious activity.
- Backup systems were accessible directly from the network and partially encrypted.

Business Impact Analysis

Operational Impact

- Disruption to internal systems (HR, finance, file access)
- staff unable to perform daily tasks.
- Potential downtime for client-facing services.

Financial Impact

- Potential ransom payment.
- Costs of incident response and system recovery.
- Loss of productivity.
- Possible regulatory fines.

Legal and Compliance Impact

- Exposure of sensitive employee and patient-related data.
- Potential breach of privacy laws.

Reputational Impact

- Loss of trust from healthcare clients and partners.
- Damage to brand credibility
- Customer attrition

Recommendations

Immediate Actions

- Isolate infected systems to prevent further spread
- Disable compromised accounts and reset all credentials
- Engage incident response and forensic specialists.
- Restore systems from clean, offline backups.
- Report breach to relevant regulatory authorities.

Long-Term Strategic Improvements

- Implement regular security awareness training for staff (phishing simulations).
- Adopt Zero Trust security model.
- Strengthen email filtering and anti-phishing controls.
- Segment networks to limit lateral movement and network wide breach.
- Ensure maintaining secure and offline backups.
- Conduct regular penetration testing and vulnerability assessments.

Lessons Learned

- Human factors remain a primary attack vector (phishing).
- Detection mechanisms need strengthening.
- Backup systems must be isolated and hardened.
- Strong Identity Access Management (IAM) is critical in limiting attack spread.

Conclusion

This ransomware attack highlights critical gaps in Orion Health Services' cybersecurity posture, particularly in user awareness, access control, and system monitoring. While the attack caused significant disruption and data exposure, implementing the recommended controls will greatly reduce the likelihood and impact of future incidents.

A proactive, layered security approach is essential to protect sensitive healthcare data and maintain trust with clients and stakeholders.

Prepared by

Yosief Araya

04/05/2026